

NETWORKWALKS

Penetration Testing Report

Mediroza General Hospital

Batch B083 | Week 4

Target: <https://medirozahospital.com>

CLIENT

Mediroza General Hospital

TYPE

Black-box Penetration Test

PREPARED BY

Emmanuel Balami

CLASSIFICATION

Confidential — Authorised Personnel Only

1. Executive Summary

Between 30 September and 2 October 2026, NetworkWalks conducted an authorised black-box penetration test against the public-facing web infrastructure of Mediroza General Hospital (<https://medirozahospital.com>), as part of the NetworkWalks Cybersecurity Internship Program (Batch B083, Week 4). The engagement was limited to the target domain, with no social engineering or denial-of-service testing permitted.

The assessment identified a Critical-severity SQL injection vulnerability in the Patient Portal login form that allowed complete authentication bypass without valid credentials. Once authenticated, three patients' confidential pathology lab reports were accessible and, despite being password-protected, were secured with weak, easily-guessed passwords that offline cracking defeated within seconds.

Independently of the login bypass, reconnaissance of the site's robots.txt file disclosed the existence of a legacy /old/ directory that was both excluded from search engines and left completely unprotected, with directory listing enabled. This exposed a full, unauthenticated database backup containing the hospital's entire staff payroll (30 employees, including salaries and national ID numbers) and its shareholder capitalisation table.

Taken together, these findings represent severe risk to patient confidentiality, staff privacy, and the hospital's financial and ownership information. Both root causes – unsanitised SQL input and an unprotected legacy backup – are common, well-understood, and straightforward to remediate. Section 6 provides specific, actionable recommendations for each.

2. Scope and Methodology

Project Type	Penetration Testing & Vulnerability Assessment
Client Name	Mediroza General Hospital
Target	https://medirozahospital.com
Testing Type	Black-box (no prior credentials or internal knowledge provided)
Scope	medirozahospital.com only. No social engineering, no denial-of-service, no testing outside the agreed domain.
Authorisation	Written authorisation provided by the client for security testing of their web infrastructure.
Duration	5 days
Tester	Emmanuel Balami — NetworkWalks Cybersecurity Program (Batch B083)

Testing followed a standard black-box web application methodology: passive and active reconnaissance, content and directory discovery, authentication testing, and post-exploitation data review. No source code, credentials, or internal documentation were provided ahead of testing. The following tools were used:

Tool	Purpose
whois	Domain registration reconnaissance
whatweb	Web technology / server fingerprinting
dnsrecon	DNS record enumeration
gobuster	Directory and file brute-forcing

Tool	Purpose
curl	Manual HTTP request crafting, header inspection, cookie handling
Manual SQL injection testing	Authentication bypass testing against login forms
pdfcrack	Dictionary attack against password-protected PDF files
rockyou.txt	Password wordlist used for PDF cracking

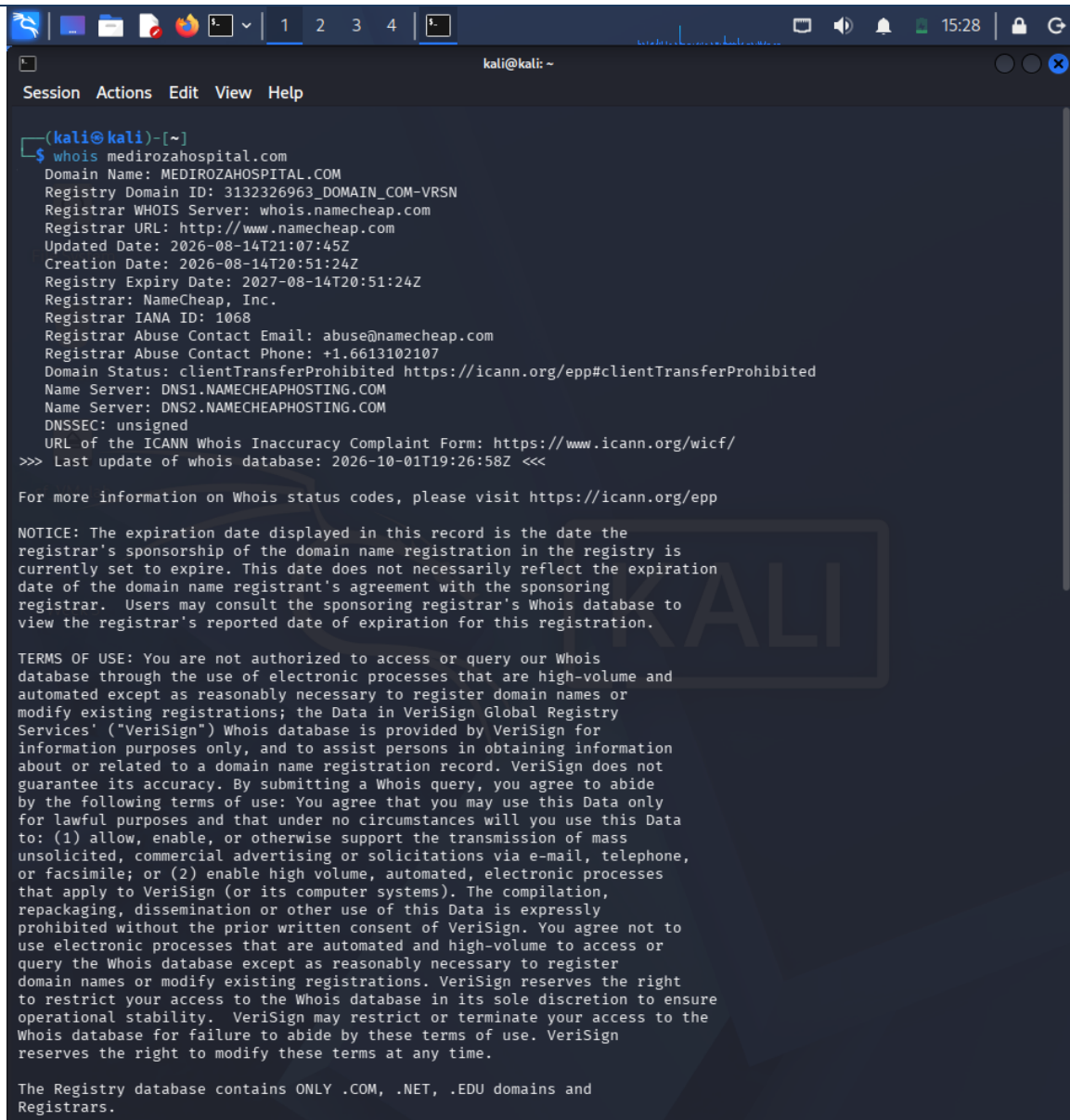
Limitations

The site's bot-protection mechanism (a JavaScript cookie gate) initially blocked automated tooling, including whatweb and sqlmap's default requests. This was bypassed by manually setting the static hc_js_gate cookie the gate itself issues – itself a finding, documented in Section 5. No further limitations affected the assessment.

3. Findings and Proof of Exploitation

3.1 Reconnaissance

Initial reconnaissance established the target's registrar, hosting, and DNS infrastructure, and began mapping the site's content.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ whois medirozahospital.com  
Domain Name: MEDIROZAHOSPITAL.COM  
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.namecheap.com  
Registrar URL: http://www.namecheap.com  
Updated Date: 2026-08-14T21:07:45Z  
Creation Date: 2026-08-14T20:51:24Z  
Registry Expiry Date: 2027-08-14T20:51:24Z  
Registrar: NameCheap, Inc.  
Registrar IANA ID: 1068  
Registrar Abuse Contact Email: abuse@namecheap.com  
Registrar Abuse Contact Phone: +1.6613102107  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Name Server: DNS1.NAMECHEAPHOSTING.COM  
Name Server: DNS2.NAMECHEAPHOSTING.COM  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>>> Last update of whois database: 2026-10-01T19:26:58Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/epp  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiration  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
automated except as reasonably necessary to register domain names or  
modify existing registrations; the Data in VeriSign Global Registry  
Services' ("VeriSign") Whois database is provided by VeriSign for  
information purposes only, and to assist persons in obtaining information  
about or related to a domain name registration record. VeriSign does not  
guarantee its accuracy. By submitting a Whois query, you agree to abide  
by the following terms of use: You agree that you may use this Data only  
for lawful purposes and that under no circumstances will you use this Data  
to: (1) allow, enable, or otherwise support the transmission of mass  
unsolicited, commercial advertising or solicitations via e-mail, telephone,  
or facsimile; or (2) enable high volume, automated, electronic processes  
that apply to VeriSign (or its computer systems). The compilation,  
repackaging, dissemination or other use of this Data is expressly  
prohibited without the prior written consent of VeriSign. You agree not to  
use electronic processes that are automated and high-volume to access or  
query the Whois database except as reasonably necessary to register  
domain names or modify existing registrations. VeriSign reserves the right  
to restrict your access to the Whois database in its sole discretion to ensure  
operational stability. VeriSign may restrict or terminate your access to the  
Whois database for failure to abide by these terms of use. VeriSign  
reserves the right to modify these terms at any time.  
  
The Registry database contains ONLY .COM, .NET, .EDU domains and  
Registrars.
```

Figure 1 — WHOIS lookup of medirozahospital.com (registered via NameCheap, Inc.)

A directory brute-force scan (gobuster) against the site surfaced two files of immediate interest: robots.txt and sitemap.xml, both returning HTTP 200.

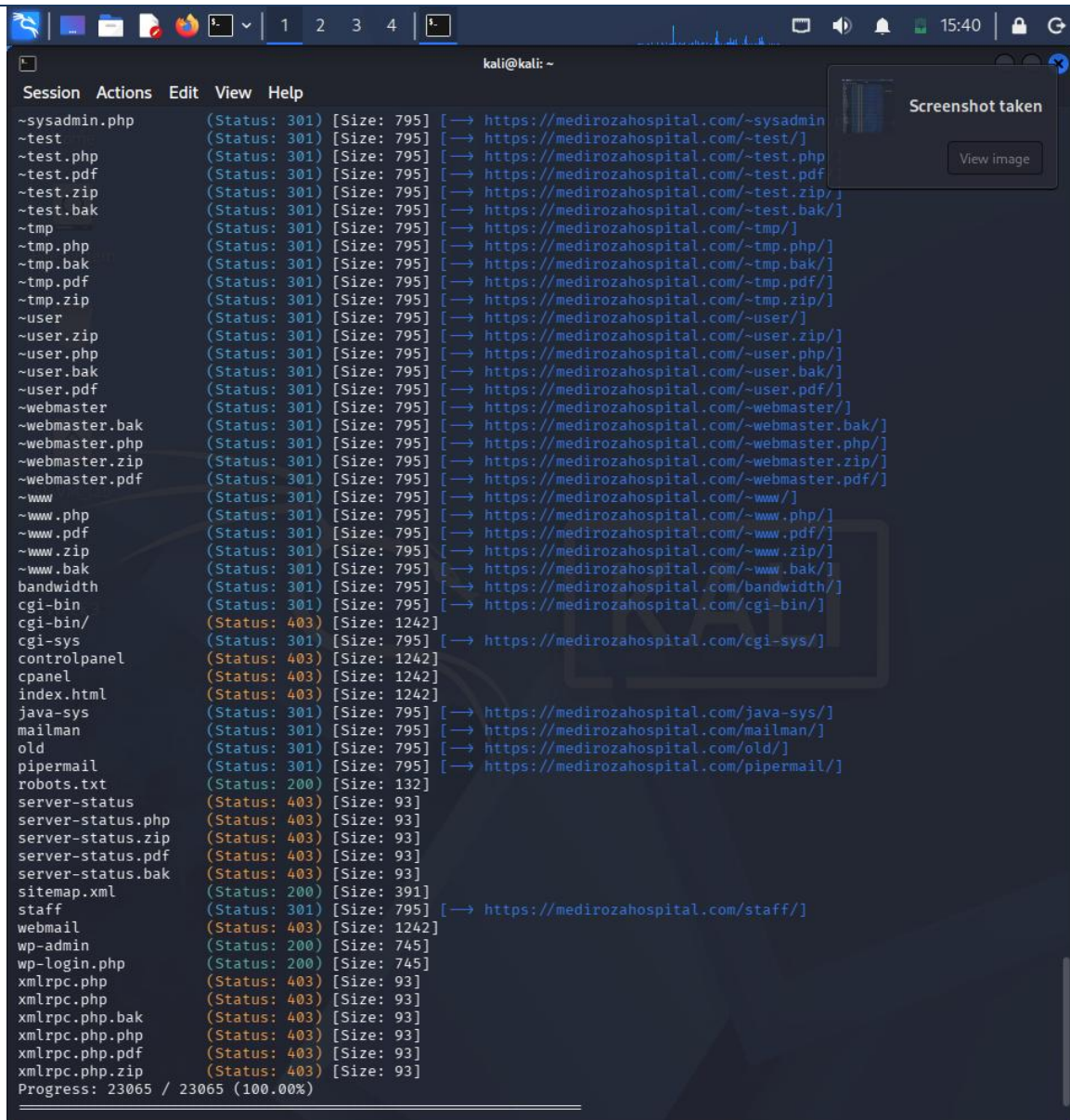


Figure 2 – gobuster directory scan locating robots.txt and sitemap.xml

Fetching robots.txt directly disclosed three paths the site owner explicitly wanted excluded from search engines: /patient/, /staff/, and /old/. This is the starting point for both the authentication bypass (3.2) and the data exposure (3.3) below – robots.txt effectively handed over a map of the site's most sensitive areas.

3.2 SQL Injection – Patient Portal Authentication Bypass

The Patient Portal login form (/patient/login.php) was tested for SQL injection by submitting a single quote in the username field. The application responded with a raw, unhandled MySQL error, confirming that user input was being concatenated directly into a SQL query without sanitisation or parameterisation.

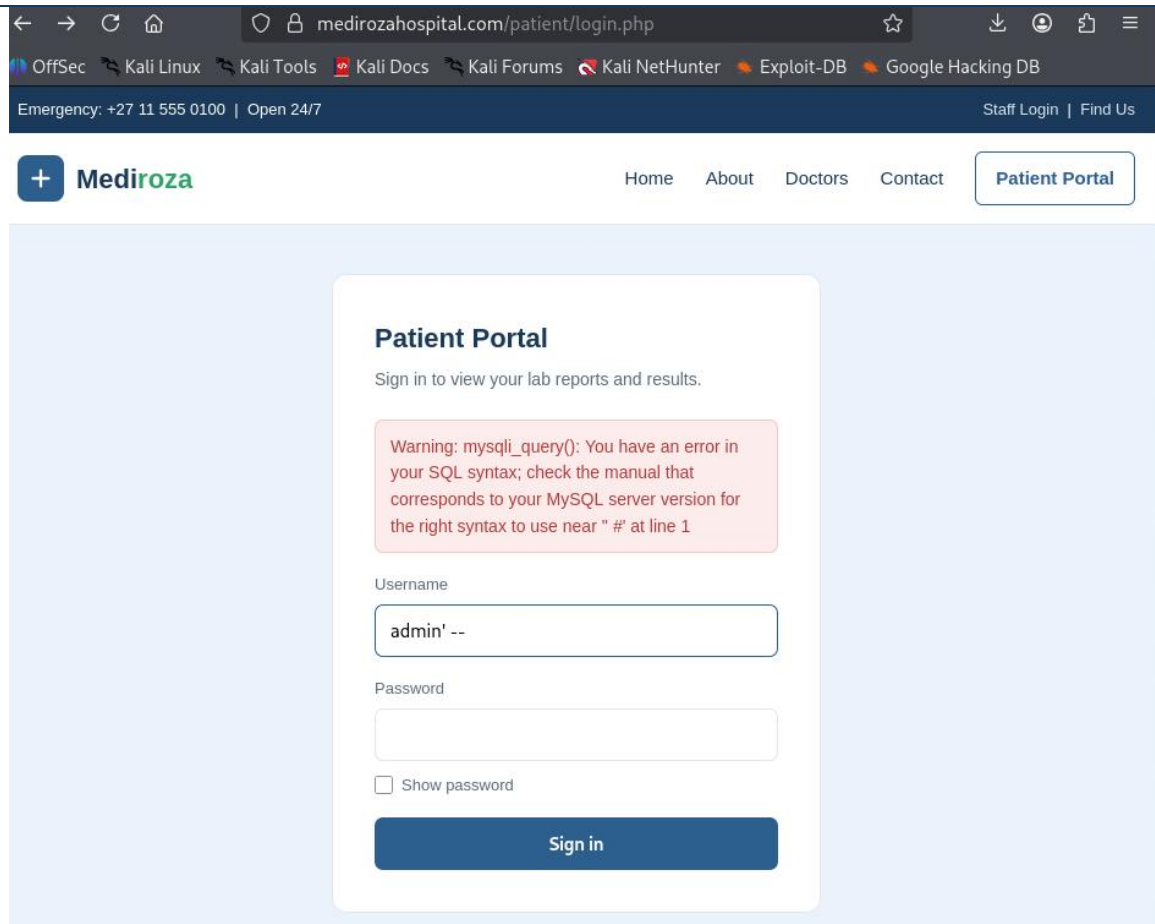


Figure 3 — Unsanitised input triggering a raw `mysqli_query()` syntax error

Refining the payload to `admin' --` (a single quote closing the username string literal, followed by a SQL comment marker with a trailing space to correctly comment out the remainder of the query, including the password check) achieved a full authentication bypass. No valid password was required.

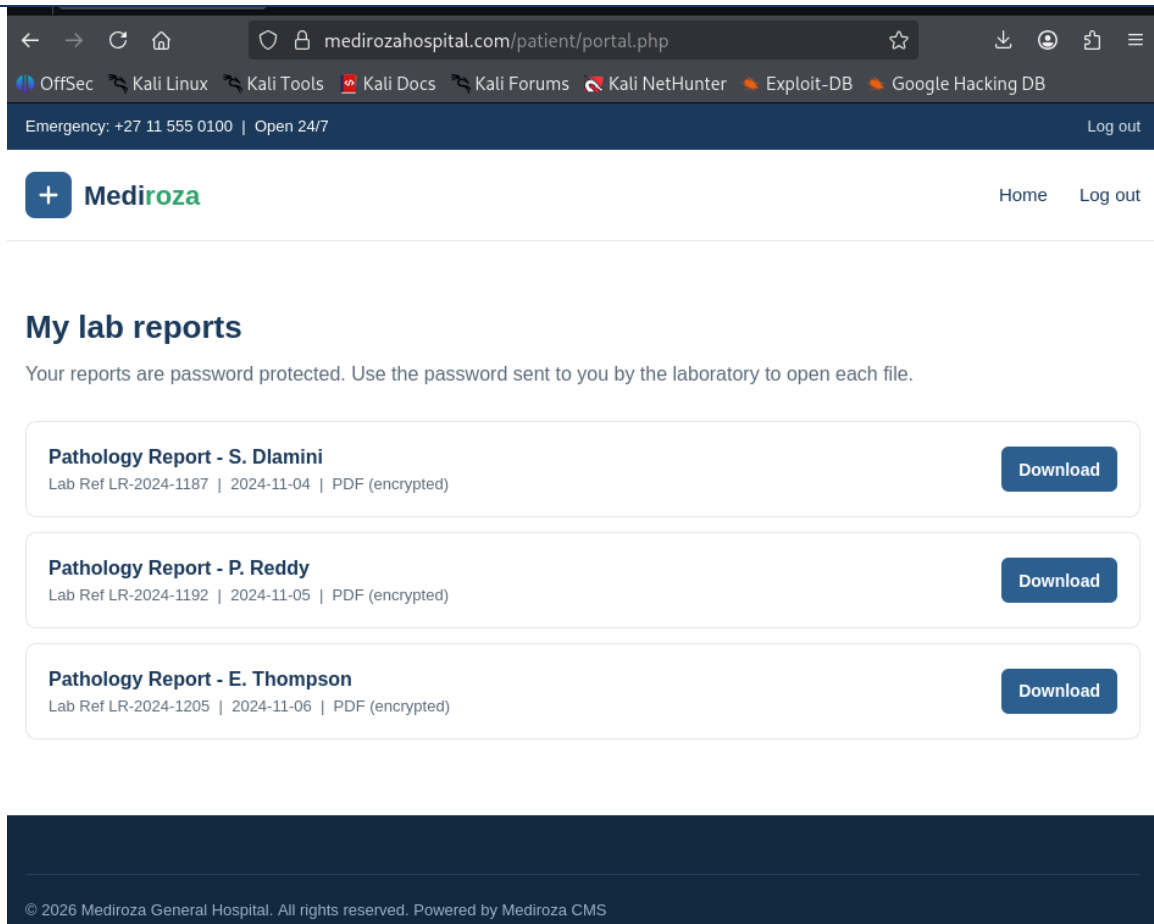


Figure 4 — Successful authentication bypass landing on /patient/portal.php, listing three patients' lab reports

This single flaw is sufficient, on its own, to compromise the confidentiality of every patient record accessible through the portal.

3.3 Sensitive Data Exposure – Unprotected Legacy Backup

Following the robots.txt lead, the /old/ directory was found to have directory listing enabled, exposing a single file: mediroza_db_backup_2019.sql (7KB), downloadable without any authentication.

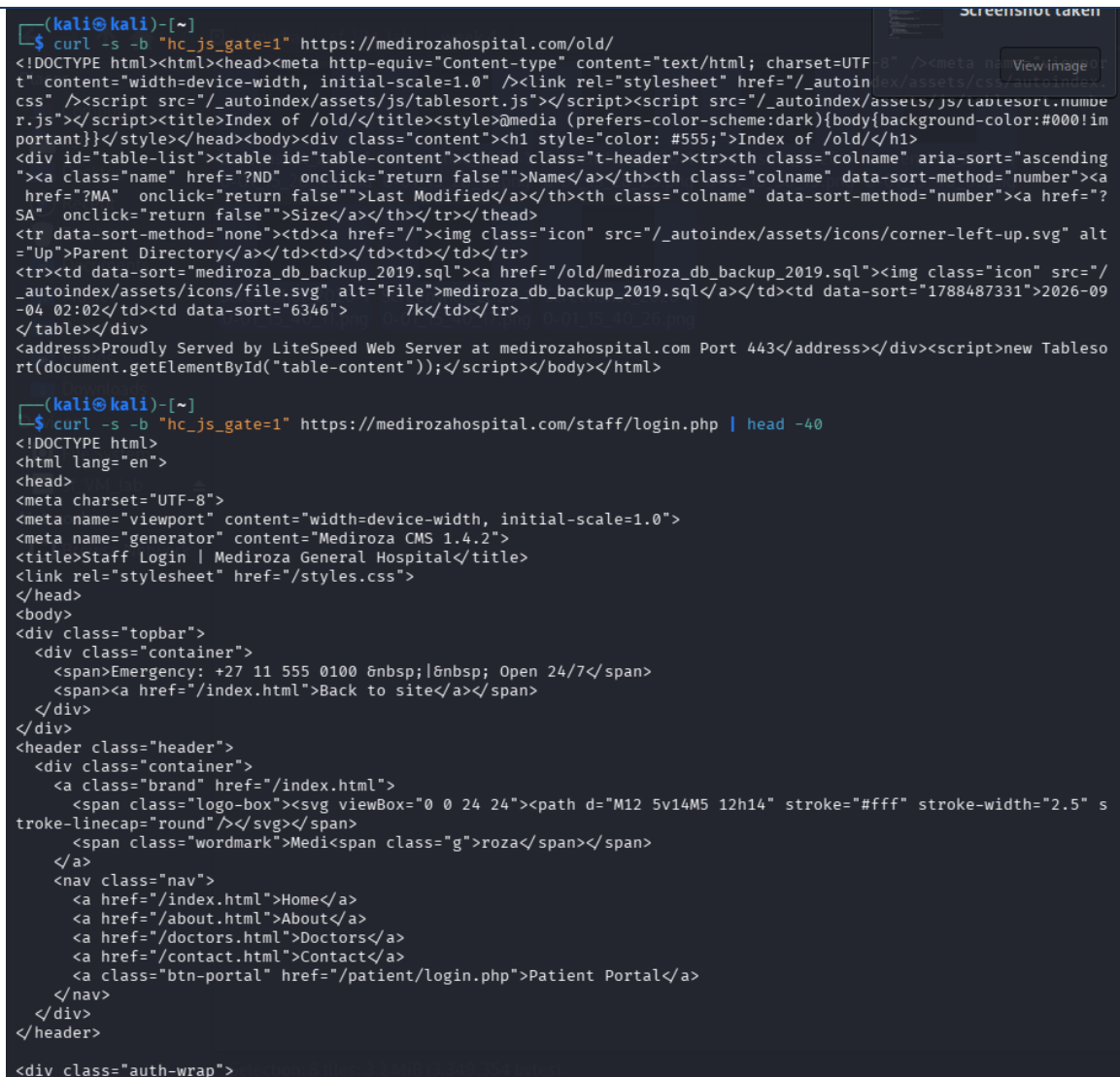


Figure 5 – Unauthenticated directory listing of /old/ exposing the database backup

The backup contained two complete tables from the hospital's internal HR database (mediroza_hr): a staff table with 30 employee records – full name, job title, department, email, phone number, national ID number, monthly salary (ZAR), and date joined – and a shareholders table listing the hospital's 10 shareholders and their respective ownership percentages and share classes.

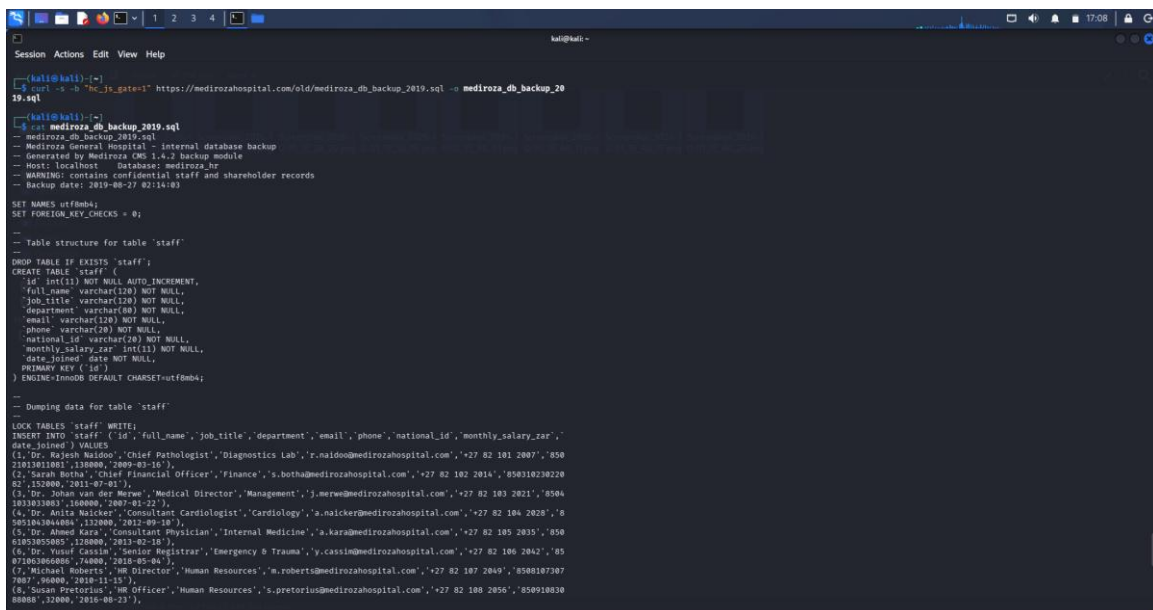
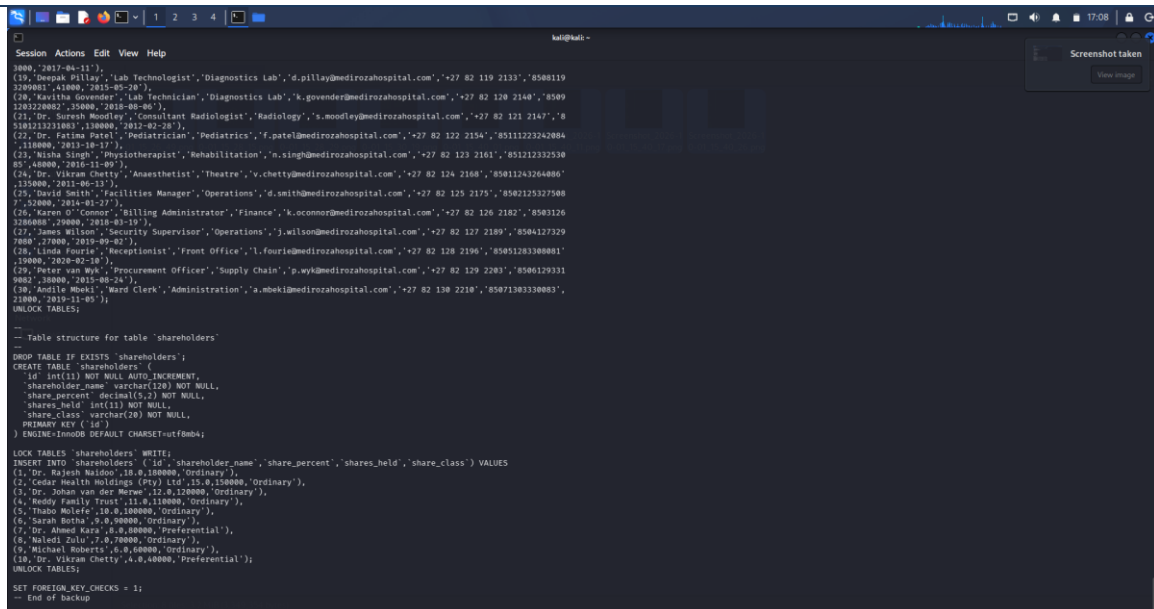


Figure 6 – Staff payroll and national ID records exposed in the database backup



```
Session Actions Edit View Help
19800, '2017-04-11'),
(19, 'Deepak Pillay', 'Lab Technician', 'Diagnostics Lab', 'd.pillay@medirozahospital.com', '+27 82 119 2133', '8508119
3209083', 41000, '2015-05-20'),
(20, 'Kavitha Govender', 'Lab Technician', 'Diagnostics Lab', 'k.govender@medirozahospital.com', '+27 82 120 2140', '8509
1283228002', 35000, '2015-08-05'),
(21, 'Dr. Suresh Moodley', 'Consultant Radiologist', 'Radiology', 's.moodley@medirozahospital.com', '+27 82 121 2147', '8
130312131803', 110000, '2015-02-28'),
(22, 'Dr. Fatima Patel', 'Pediatrician', 'Pediatrics', 'f.patel@medirozahospital.com', '+27 82 122 2154', '8511123242084
118000, '2015-10-17'),
(23, 'Nisha Singh', 'Physiotherapist', 'Rehabilitation', 'n.singh@medirozahospital.com', '+27 82 123 2161', '851212332530
85', 48000, '2016-11-09'),
(24, 'Dr. Vikram Chetty', 'Anaesthetist', 'Theatre', 'v.chetty@medirozahospital.com', '+27 82 124 2168', '85011243264080',
135000, '2011-06-13'),
(25, 'David Smith', 'Facilities Manager', 'Operations', 'd.smith@medirozahospital.com', '+27 82 125 2175', '8502125327508
7', 52000, '2014-01-27'),
(26, 'Karen O'Connor', 'Billing Administrator', 'Finance', 'k.oconnor@medirozahospital.com', '+27 82 126 2182', '8503126
128000', '2006', '2012-03-15'),
(27, 'James Wilson', 'Security Supervisor', 'Operations', 'j.wilson@medirozahospital.com', '+27 82 127 2189', '8504127329
8000, '27000, '2015-09-02'),
(28, 'Linda Fourie', 'Receptionist', 'Front Office', 'l.fourie@medirozahospital.com', '+27 82 128 2196', '85051283300801',
15000, '2020-02-10'),
(29, 'Peter van Wyk', 'Procurement Officer', 'Supply Chain', 'p.wyk@medirozahospital.com', '+27 82 129 2203', '8506129331
9003', 38000, '2015-08-24'),
(30, 'Anette Mooki', 'Ward Clerk', 'Administration', 'a.mooki@medirozahospital.com', '+27 82 130 2210', '85071303300083',
21000, '2019-11-05'),
UNLOCK TABLES;
--
-- Table structure for table 'shareholders'
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`, `shareholder_name`, `share_percent`, `shares_held`, `share_class`) VALUES
(1, 'Dr. Rajesh Naidoo', 10.0, 100000, 'Ordinary'),
(2, 'Cedar Health Holdings (Pty) Ltd', 15.0, 150000, 'Ordinary'),
(3, 'Dr. Johan van der Merwe', 12.0, 120000, 'Ordinary'),
(4, 'Reddy Family Trust', 11.0, 110000, 'Ordinary'),
(5, 'Thabo Mulafe', 10.0, 100000, 'Ordinary'),
(6, 'Sarah Botha', 9.0, 90000, 'Ordinary'),
(7, 'Dr. Ahmed Kazi', 8.0, 80000, 'Preferential'),
(8, 'Naledi Zulu', 7.0, 70000, 'Ordinary'),
(9, 'Michael Roberts', 6.0, 60000, 'Ordinary'),
(10, 'Dr. Vikram Chetty', 4.0, 40000, 'Preferential');
UNLOCK TABLES;
SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure 7 – Hospital shareholder capitalisation table exposed in the same backup

Salaries across the 30 staff records range from R19,000/month (Receptionist) to R160,000/month (Medical Director). Shareholdings range from 4% to 18%, held by a mix of senior medical staff, an HR director, a network engineer, and two corporate/trust entities (Cedar Health Holdings (Pty) Ltd and the Reddy Family Trust). This is commercially and personally sensitive information with no legitimate reason to be publicly accessible.

3.4 Weak Encryption on Retrieved Patient Lab Reports

The three lab report PDFs retrieved via the Patient Portal bypass (3.2) were password-protected. All three were defeated using pdfcrack against the standard rockyou.txt wordlist, with none requiring more than a brief dictionary run:

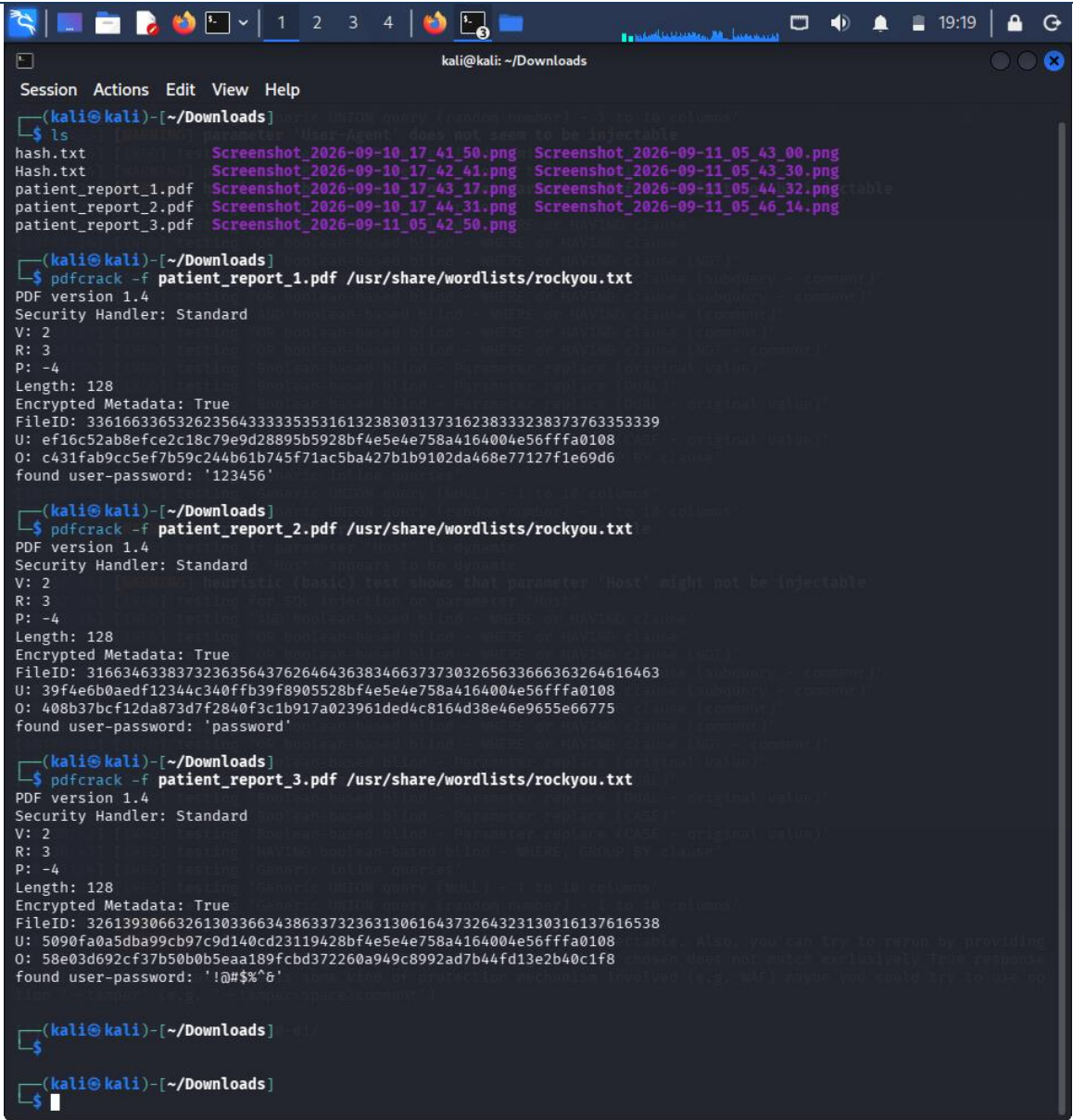


Figure 8 – pdfrack recovering all three PDF passwords via dictionary attack

File	Patient	Password	Lab Ref
patient_report_1.pdf	Sipho Dlamini	123456	LR-2024-1187
patient_report_2.pdf	Priya Reddy	password	LR-2024-1192
patient_report_3.pdf	Emily Thompson	!@#\$\$%^&	LR-2024-1205

Each report contains full pathology results tied to an identifiable patient (name, date of birth, patient ID, referring doctor, and test results with abnormal values flagged):

The screenshot shows a web browser window with the following details:

- Browser Tabs:** My Reports | Mediroz, patient_report_3, patient_report_2, Pathology Report - S.
- Address Bar:** file:///home/kali/Downloads/patient_report_1.pdf
- Page Header:** Mediroza General Hospital, 14 Cedar Avenue, Johannesburg, South Africa, Tel: +27 11 555 0100, medirozahospital.com
- Section Header:** PATHOLOGY LABORATORY REPORT (CONFIDENTIAL)
- Patient Information:**
 - Patient Name: Sipho Dlamini
 - Patient ID: MG-P-10231
 - Date of Birth: 1984-06-12
 - Gender: Male
 - Report Date: 2024-11-04
 - Referring Dr: Dr. Anita Naicker
 - Specimen: Whole blood (EDTA)
 - Lab Ref No: LR-2024-1187
- Test Results Table:**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 9 – Recovered pathology report for patient Sipho Dlamini (elevated white cell count)

The screenshot shows a web browser window with the following details:

- Browser Tabs:** My Reports | Mediroz, patient_report_3, Pathology Report - P, Pathology Report - S.
- Address Bar:** file:///home/kali/Downloads/patient_report_2.pdf
- Browser Extensions:** OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB.
- Page Content:**
 - Mediroza General Hospital** logo and contact information: 14 Cedar Avenue, Johannesburg, South Africa, Tel: +27 11 555 0100, medirozahospital.com.
 - PATHOLOGY LABORATORY REPORT** (CONFIDENTIAL)
 - Patient Information:**
 - Patient Name: Priya Reddy
 - Patient ID: MG-P-10244
 - Date of Birth: 1991-02-28
 - Gender: Female
 - Report Details:**
 - Report Date: 2024-11-05
 - Referring Dr: Dr. Johan van der Merwe
 - Specimen: Serum
 - Lab Ref No: LR-2024-1192
 - Test Results Table:**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure 10 – Recovered pathology report for patient Priya Reddy (elevated cholesterol markers)

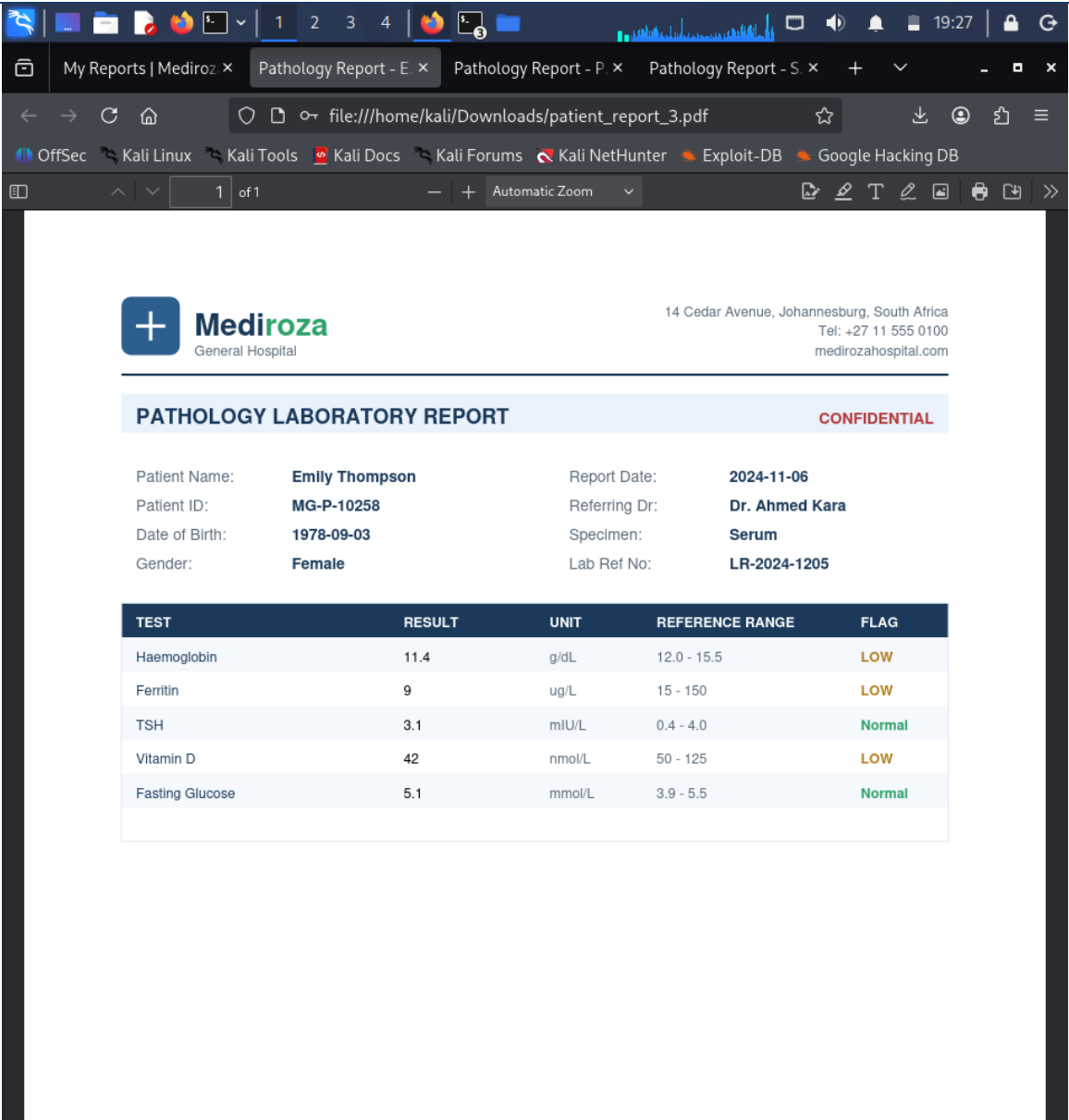


Figure 11 – Recovered pathology report for patient Emily Thompson (low haemoglobin, ferritin, vitamin D)

4. Risk Rating

Each finding below is rated using a standard four-level scale (Critical / High / Medium / Low), considering both the ease of exploitation observed during testing and the sensitivity of the data or access each vulnerability exposes.

#	Vulnerability	Evidence	Impact	Risk
1	SQL Injection — Authentication Bypass (Patient Portal)	Unsanitised 'username' field on /patient/login.php allowed a crafted input (admin' --) to alter the login query and bypass authentication entirely, without a valid password.	Complete bypass of patient authentication; full access to any patient's confidential pathology lab reports.	Critical
2	Verbose Database Error Disclosure	A malformed SQL payload returned a raw mysqli_query() error, revealing the backend uses MySQL and exposing internal query structure.	Materially assists an attacker in refining injection payloads and fingerprinting the backend.	Medium

#	Vulnerability	Evidence	Impact	Risk
3	Sensitive Data Exposure – Unprotected Legacy Directory	robots.txt disclosed a disallowed /old/ path; directory listing was left enabled there, exposing mediroza_db_backup_2019.sql for unauthenticated download.	Full HR database compromise: 30 staff records (salaries, emails, phone numbers, national ID numbers) and the hospital's 10-entry shareholder cap table.	● Critical
4	robots.txt Information Disclosure	robots.txt explicitly lists sensitive paths (/patient/, /staff/, /old/) intended to be hidden from search engines, effectively acting as a roadmap for an attacker.	Shortens reconnaissance time and directly points to the two findings above.	● Low
5	Weak PDF Encryption Passwords	All 3 patient lab report PDFs retrieved from the portal were protected with weak, dictionary-crackable passwords (123456, password, !@#%\$^&).	Even if the portal-level vulnerability above is fixed, the documents themselves offer negligible protection against offline cracking.	● High
6	Bot-protection Bypass via Static Cookie	The site's JavaScript 'checking your browser' gate could be bypassed by manually setting a single static cookie (hc_js_gate=1), with no real challenge-response behind it.	Provides no meaningful protection against automated scanning or attack tooling.	● Low

Risk level key: ● **Critical** ● **High** ● **Medium** ● **Low**

The two Critical findings – the SQL injection auth bypass and the exposed database backup – are independent of each other (different root causes, different entry points) but compound one another: an attacker does not need to exploit both to cause serious harm, and either alone constitutes a reportable data breach under most healthcare data protection regimes.

5. Recommendations and Remediation

- Fix SQL Injection immediately (Critical). Rewrite all database queries on /patient/login.php and /staff/login.php to use parameterised queries / prepared statements (e.g. PDO or mysqli prepared statements). Never concatenate raw user input into SQL strings. This is the single highest-priority fix.
- Disable verbose database errors in production (Medium). Set display_errors = Off in PHP configuration and implement generic, logged error handling so raw database errors are never returned to the client.
- Remove the /old/ directory from the production web root entirely (Critical). Legacy and backup files should never be stored inside a publicly reachable directory. Move backups to storage outside the webroot with no public HTTP access, and audit for any other legacy content.
- Disable directory listing server-wide (High). Configure the web server (LiteSpeed) to return 403 Forbidden for any directory without an index file, regardless of path.
- Rotate all exposed credentials and sensitive identifiers. Treat every national ID number and any reused passwords in the exposed backup as compromised; notify affected staff per applicable data protection obligations.
- Stop listing sensitive paths in robots.txt (Low). robots.txt is publicly readable by definition; sensitive paths should be protected by proper authentication and access control, not merely asked not to be indexed.

7. Enforce strong password policies for patient-facing document encryption (High). Lab report PDFs should use system-generated, high-entropy passwords delivered through a secure out-of-band channel, never short dictionary words.
8. Replace the static-cookie bot gate with genuine bot mitigation (Low), such as a real challenge-response mechanism or a reputable third-party WAF/bot-management service, if automated-traffic filtering is actually required.
9. Conduct a full authenticated code review of Mediroza CMS 1.4.2, given that a single unauthenticated black-box test surfaced a critical injection flaw within hours – further undiscovered issues should be assumed likely.
10. Re-test after remediation. Engage NetworkWalks (or an equivalent independent tester) to verify each fix before considering this engagement closed.

6. Conclusion

This engagement met its objectives: unauthenticated access to confidential patient lab reports was achieved via a Critical SQL injection vulnerability, and a separate Critical data exposure gave unauthenticated access to the hospital's complete staff payroll and shareholder records. Both issues stem from fundamental, well-known security weaknesses — unsanitised database queries and an unprotected legacy directory — rather than sophisticated attack techniques, underscoring how much risk basic security hygiene gaps can carry for an organisation handling health data.

NetworkWalks recommends Mediroza General Hospital treat the findings in this report as urgent, prioritise the remediation steps in Section 6 in the order listed, and commission a re-test to confirm resolution before considering the environment secure.

— End of Report —

Prepared by: Emmanuel Balami

NetworkWalks Cybersecurity Program (Batch B083) – Week 4

This assessment was conducted in a controlled, authorised environment for educational purposes. These techniques must never be applied to any system without explicit written permission from the owner.